Malicious Code Analysis : CMU Heinz College 95-759
Assignment #1 : Malware Families

Name: Brendan Reed
Date: 21 January 2026

Exercises:

1. Describe in your own words some of the differences between malware analysts and reverse engineers. Frame your response by comparing economic factors such as time and energy spent with respect to various tasks.

The difference between malware analysts (MA) and reverse engineers (RE) lies in their engagement with the complexities of malware samples, exploits, and their consequences. The role of a malware analyst is typically exposed to a wider array of tasks than a reverse engineer is. For example, a MA is more on the front lines of detection, protection from, and initial triaging of malware samples across a wide array of types and malware families. These skills are particularly useful to a security operations center or internal IT team which is responsible for protection of devices and organizations.

A reverse engineer however is much less on the front lines of detection and response and takes what I would call 'escalations' from malware analysts or other teams. Instead of working reactively on incidents involving a large number of malware samples, Reverse Engineers are much more focused on the research side of this analysis. The research of an RE is more focused and deeper on a single malware sample or family than the work of a Malware Analyst. RE's must be deeply knowledgeable with the software/OS their malware family is targeting to potentially uncover vulnerabilities, as well as creating indicators of compromise for organizations and threat researchers.

EC-Council. (2023, November 7). *A quick guide to reverse engineering malware* . Cybersecurity Exchange. https://www.eccouncil.org/cybersecurity-exchange/ethical-hacking/malware-reverse-engineering/

Malware analysis | CISA. (n.d.). https://www.cisa.gov/resources-tools/services/malware-analysis

What does a reverse engineer do in cybersecurity. Huntress. (n.d.). https://www.huntress.com/cybersecurity-101/topic/what-does-a-reverse-engineer-do-cybersecurity

Written by Steven Bowcut – Last updated: September 11. (2025, September 11). *Malware analyst careers: Your ultimate playbook*. Cybersecurity Guide. https://cybersecurityguide.org/careers/malware-analyst/

2. Research the malware family China Chopper Web shell. Describe in your own words how it works on the server side. How can such a small piece of code be capable of so much? Research the client-side program and enumerate some of the capabilities afforded to the operator.

China Chopper is a 4KB backdoor web shell which acts as a means to connect a compromised web server to a malicious actor's command and control server. The China Chopper is such a small payload because its only job is to exploit a weakness in Windows Server R2 and IIS to open a web shell. Once the server-side payload is delivered, its sole purpose is to accept HTTP requests from an attacker and execute the contents of those requests using the server's own scripting engine.

The actual malicious code originates elsewhere, from a remote command server. The web shell on the server side only helps to open a communication channel and hijack the running processes of Windows IIS.

The reason China Chopper can do so much with so little code is because it reuses tools that already exist on the server. IIS already knows how to read files, run system commands, and otherwise interact with Windows Server. The attacker-side GUI allows file management, remote code execution through the terminal, and running SQL queries.

Cn. (n.d.). *China Chopper Webshell - the 4KB that owns your web server*. China Chopper Webshell - the 4KB that Owns your Web Server. https://informationonsecurity.blogspot.com/2012/11/china-chopper-webshell.html

Google. (n.d.). *Breaking down the china chopper web shell - part I | mandiant | google cloud blog*. Google. https://cloud.google.com/blog/topics/threat-intelligence/breaking-down-china-chopper-web-shell-part-i/

White, J. (2024, June 6). *Analyzing attacks against Microsoft Exchange Server with china Chopper Webshells*. Unit 42. https://unit42.paloaltonetworks.com/china-chopper-webshell/

3. Oftentimes the term Command and Control (C2) is thrown around as anything malware communicates with, but that is not the case. Define in your own words Command and Control.

I believe C2 is referred to as this one-way communication channel because of its place on the cyber kill chain. Command and control is truly the entire infrastructure for remote management, persistence, replication, and lateral movement of malware within a target network. Importantly, Command and Control is used to carry out the final stages of an attack. This process can include exfiltrating data, encrypting information, or launching further attacks. Additionally, this stage of any cyber threat may be leveraged to build out even more offensive tactics. For example, if a host is detected to be running an antivirus the malware is not equipped to handle, a Command and Control server may be useful to evolve a piece of malware.

I was surprised to learn that Command and Control is also defined as an attack method itself. A Command-and-Control attack occurs when an attacker uses a server to send commands to, and receive data from, computers compromised by malware. C2 can be used to further exploit a target network by performing various malicious actions such as data discovery, malware spreading, or denial of service attacks. Examples of Command and Control attacks are Botnets and Distributed Denial Service attacks.

Command and control (C&C) attacks. Command and Control (C&C) Attacks. (n.d.). https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/command-and-control-cac-attack/

What are the Cyber kill chain stages? step Six: Command and control | fortra. (n.d.). https://www.fortra.com/blog/what-are-cyber-kill-chain-stages-step-six-command-and-control

What is a command-and-control attack?. Fortinet. (n.d.). https://www.fortinet.com/resources/cyberglossary/command-and-control-attacks

What is Command Control Server?: Adaptive security glossary. What is Command Control Server? | Adaptive Security Glossary. (n.d.). https://www.adaptivesecurity.com/glossary/command-control-server

4. What are some factors that make it difficult to pin a specific file to a given malware family? Name at least two.

An important factor to consider when categorizing malware into families is the fact that malware is constantly evolving and frequently modified. Even though a piece of code might have one single original source, the constant "code drift" by authors often leads to a piece of malware appearing drastically different from its original source. These changes result in a completely different file hash or appearance to the original *master*, but still belong to one malware family. This can make it difficult or time consuming to correctly identify the malware family for each new signature.

Another factor that makes classification difficult is the use of obfuscation and intentionally misleading areas of code. Malware regularly displays polymorphic characteristics which makes analysis of its true underlying functions difficult to decode. Additionally, in cybersecurity it is not uncommon for threat actors to include pieces of code or comments as a false flag to try and frame other groups or nation states for an attack. An example of this the Olympic Destroyer malware in 2018 which originally appeared to originate from Russia but was later determined to be a framing attempt by the group Lazarus Group/SWIFT Bangladesh.

Excerpt, A. G. (2019, October 17). *Inside olympic destroyer, the most deceptive hack in history*. Wired. https://www.wired.com/story/untold-story-2018-olympics-destroyer-cyberattack/

Securonix Threat Research: Olympic destroyer aka notpetya V2 "false flag" cyber sabotage attack detection using security analytics. Securonix. (2021, October 21). https://www.securonix.com/blog/securonix-threat-research-olympic-destroyer-aka-notpetya-v2-false-flag-cyber-sabotage-attack-detection-using-security-analytics/

5. Describe the following anti analysis techniques; anti-reversing, anti-emulation, and anti-debugging. For each response, give an example. For anti-reversing describe various means to make reverse engineering more difficult (more specifically, think program obfuscation and encoding!).

Anti-reversing refers to any techniques used by malware authors that make it difficult for reverse engineers to perform static analysis of a piece of malware. Tactics that mask the code's internal logic or assembly code, can change how the malware appears without changing its behavior. An example of this can be obfuscation by inserting pieces of code from different malware families to make deciphering it more difficult and mislead a reverse engineer. Another tactic used is encoding which encodes readable text in a cipher or other encrypted method which is another piece of the puzzle a reverse engineer must solve.

Anti-emulation is a characteristic of polymorphic malware which can detect when it is being run outside of a normal production environment. Malware analysis is primarily carried out in a virtualized environment or a sandbox to observe key behaviors and decrypt it. Some malware will include code that detects when it is in such an environment by looking at pieces of the OS environment it is running in such as hardware and CPU timing. If it detects it is not on a target machine, it can completely change its structure to be harder to observe. A way around this is a dedicated offline machine for specifically malware analysis.
Anti-debugging can be similar to anti-emulation in that a piece of malware will detect when it is being broken apart and analyzed by debugger tools. Pieces of code can change to intentionally slow down efforts to understand the code's true purpose. A sophisticated malware may be able to skip malicious sections of code if it detects such an environment.

Anti-disassembly, anti-debugging and anti-VM. Infosec. (n.d.-a). https://www.infosecinstitute.com/resources/malware-analysis/anti-disassembly-anti-debugging-and-anti-vm/

Anti-disassembly, anti-debugging and anti-VM. Infosec. (n.d.-b). https://www.infosecinstitute.com/resources/malware-analysis/anti-disassembly-anti-debugging-and-anti-vm/

Scribd. (n.d.). *Lecture no 11*. Scribd. https://www.scribd.com/document/836352858/Lecture-no-11

YUCEEL, H. C. (2023, May 24). *Virtualization/sandbox evasion - how attackers avoid malware analysis*. THE COMPLETE SECURITY VALIDATION PLATFORM. https://www.picussecurity.com/resource/virtualization/sandbox-evasion-how-attackers-avoid-malware-analysis

6. Imagine you were creating a piece of software meant to remotely administer devices. Name three features you would think to incorporate. Research and identify a malware family that closely resembles your criteria.

As an IT administrator, I have a range of tools at my disposal for remote control and administration of devices across an array of different client environments. If I were to build and deploy a legitimate Remote Monitoring & Management (RMM) software for daily IT operations and management, these are the three core features I would be sure to implement:

1. Taking command of the Windows Update feature for automated patch checks and installation.
2. Screen access, mouse/keyboard control, and remote code execution.
3. Credential harvesting for offline use and after-hours IT support access.

These are all features that I have seen implemented to standard IT support software industry-wide. These abilities all have eerie similarities to a Remote Access Trojan (RAT). To achieve this level of access, a malicious payload would almost certainly need to be delivered disguised as another piece of software. According to Fortinet and PaloAlto, aspects of this behavior has been seen recently in the RomCom malware family called SnipBot.

Remcos malware information. (n.d.). https://success.trendmicro.com/en-US/solution/KA-0009536

What is a remote access trojan (rat)?. Fortinet. (n.d.). https://www.fortinet.com/resources/cyberglossary/remote-access-trojan

Yaron Samuel, D. R. (2024, September 23). *Inside SnipBot: The latest romcom malware variant*. Unit 42. https://unit42.paloaltonetworks.com/snipbot-romcom-malware-variant/